

# Informe de pruebas de seguridad — Sprint 8

**Proyecto:** Perfumería Victoria (tienda en línea de perfumes) · **Marco:** OWASP Top 10 (2025) · **Fecha:** 29 de septiembre de 2026 · **Ticket:** SFTWRKEY-384

## 1. Resumen ejecutivo

Se evaluaron las 10 categorías del OWASP Top 10 sobre los tres componentes del sistema: frontend (React), API (Express + PostgreSQL) y chatbot (FastAPI + LLM). La evaluación combinó revisión de código, 138 pruebas automáticas de seguridad, dos escaneos dinámicos con OWASP ZAP y auditorías de dependencias.

| Resultado                                            | Cantidad                                                |
|------------------------------------------------------|---------------------------------------------------------|
| Riesgos evaluados en la matriz                       | 45                                                      |
| Hallazgos encontrados y corregidos durante el sprint | 20                                                      |
| Riesgos aceptados con justificación                  | 2 (más 6 avisos de ZAP)                                 |
| Riesgos abiertos                                     | 3 (1 crítico, 2 medios), todos asignados a SFTWRKEY-381 |
| Verificaciones pendientes                            | 4                                                       |
| Vulnerabilidades en dependencias                     | 12 → 0 (frontend), 0 (backend), 0 (chatbot)             |
| Hallazgos de riesgo alto en ZAP                      | 0                                                       |

**Riesgo residual:** el único riesgo crítico abierto es la cuenta de administrador de demostración con contraseña pública (`seed.js`), que todavía se crea en cada despliegue de producción. Se corrige con SFTWRKEY-381 y debe cerrarse antes de la entrega.

## 2. Alcance

| Componente | Tecnología                                | Entorno evaluado                                       |
|------------|-------------------------------------------|--------------------------------------------------------|
| Frontend   | React 19, Vite, TypeScript                | Producción (Vercel) y build local                      |
| API        | Node.js 20, Express 5, PostgreSQL 16, JWT | Local con Docker Compose (mismo código que producción) |
| Chatbot    | Python 3.12, FastAPI, LLM (Ollama o Groq) | Local con Docker y pruebas con proveedor simulado      |

Los escaneos activos y las pruebas de fuerza bruta se hicieron solo en local. Contra producción solo se ejecutó el escaneo pasivo (*baseline*) de ZAP, para no cargar los servicios del plan gratuito.

## 3. Metodología

| Técnica                   | Herramienta                                                                    | Qué aporta                                                                            |
|---------------------------|--------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|
| Revisión de código        | Lectura dirigida por la matriz OWASP                                           | Encontrar riesgos antes de probarlos (método RC en la matriz)                         |
| Pruebas automáticas       | <code>node:test</code> (API), Vitest (frontend), <code>pytest</code> (chatbot) | Confirmar cada control y evitar regresiones: corren en el CI en cada push             |
| Escaneo dinámico          | OWASP ZAP 2.x ( <code>zap-baseline.py</code> )                                 | Revisar cabeceras, cookies, CSP y divulgación de información en las respuestas reales |
| Auditoría de dependencias | <code>npm audit</code> , <code>pip-audit</code>                                | Vulnerabilidades conocidas en librerías de terceros                                   |
| Pruebas manuales          | Navegador, curl, Docker                                                        | Flujos completos (login, carrito, chatbot) con la CSP de producción aplicada          |

Pruebas de seguridad automatizadas (todas pasan):

| Archivo                                | Pruebas | Categorías |
|----------------------------------------|---------|------------|
| backend/authorization.test.js          | 47      | A01, A07   |
| backend/security.accessControl.test.js | 26      | A01        |
| backend/security.injection.test.js     | 33      | A05        |
| backend/security.config.test.js        | 11      | A02, A10   |
| backend/security.alerts.test.js        | 9       | A09        |
| backend/services/rateLimit.test.js     | 3       | A07        |
| backend/cartLimits.test.js             | 2       | A06        |
| src/test/xss.test.tsx                  | 3       | A05        |
| backend/chatbot/tests/test_security.py | 4       | A05        |

Totales del proyecto al cierre: 265 pruebas de backend, 34 de frontend y 74 del chatbot, todas en verde.

## 4. Resultados por categoría

### A01 — Pérdida de control de acceso

**Qué se probó:** que un cliente no pueda leer ni modificar el perfil, los pedidos, la contraseña, el carrito o el checkout de otro usuario (IDOR); que CLIENTE y VENDEDOR no puedan usar rutas de administrador; tokens ausentes, vencidos, firmados con otra clave, con `alg: none` o con el rol alterado; IDs manipulados en la URL (`/user/07`, `/cart/-7`); y escalamiento de privilegios enviando `role` en el cuerpo. **Resultado:** todos los controles funcionan. Se encontró y corrigió un caso: un token válido pero sin `id` autorizaba `/user/undefined`, porque `String(undefined) === "undefined"` (SEC-45). **Pendiente:** verificación manual de las páginas de administración en el navegador con una cuenta de cliente (SEC-05). La protección real está en la API y está verificada.

### A02 — Configuración de seguridad incorrecta

**Qué se probó:** cabeceras HTTP, CORS, `trust proxy`, mensajes de error, endpoints internos expuestos y configuración de Docker. **Hallazgos corregidos:**

- Faltaban cabeceras de seguridad y se exponía `X-Powered-By`. Se agregó `helmet`, con una CSP estricta para la API (`default-src 'none'`).
- Sin `trust proxy`, en Render todos los clientes compartían la IP del proxy, así que el rate limit bloqueaba a todos a la vez.
- `POST /chatbot/queries` era público y escribía en la base. Ahora exige una clave interna compartida con el chatbot, comparada en tiempo constante.
- El endpoint de prueba `POST /chat/test-log` estaba expuesto. Se eliminó.
- La importación CSV devolvía mensajes internos de la base de datos. Ahora responde con un mensaje genérico.
- El sitio no tenía CSP, `X-Frame-Options` ni HSTS. Se agregaron en `vercel.json` y se verificó que ninguna página rompe.
- El contenedor de la API corría como `root` e instalaba dependencias de desarrollo. Ahora corre como `node` con `npm ci --omit=dev`.
- El CORS del chatbot permitía credenciales y cualquier método o cabecera. Se restringió.

### A03 — Fallas en la cadena de suministro de software

**Qué se probó:** `npm audit` en frontend y backend, y `pip-audit` en el chatbot. **Resultado:** el frontend tenía 12 vulnerabilidades (8 altas, entre ellas `react-router` y `react-router-dom`, que se ejecutan en el navegador). Se corrigieron con `npm audit fix`, sin cambios de versión mayor, y quedaron en 0; pruebas y build siguen pasando. El backend y el chatbot tienen 0.

## A04 — Fallas criptográficas

**Qué se probó:** almacenamiento de contraseñas, firma de tokens y transporte. **Resultado:** las contraseñas usan bcrypt con 12 rondas. Los JWT se firman con HS256 y un secreto generado por Render, expiran en 8 horas y los tokens sin firma se rechazan. Todo el tráfico de producción es HTTPS, con HSTS.

## A05 — Inyección

**Qué se probó:** 6 payloads de inyección SQL contra búsqueda, login, búsqueda de usuarios y detalle de producto; XSS almacenado en nombre, descripción y notas de productos y en respuestas del chatbot; validación del campo de imagen; *prompt injection* al chatbot. **Resultado:** todo el SQL está parametrizado: los payloads viajan siempre como parámetro y la búsqueda de SQL interpolado dio 0 coincidencias. React muestra el HTML como texto y no hay `dangerouslySetInnerHTML`. **Hallazgos corregidos:**

- El campo `image` aceptaba `javascript:`, `data:` y `http:`. Ahora solo acepta rutas locales o `https://`, en creación, edición e importación CSV.
- `PUT /products/:id` no validaba los datos como `POST`. Ahora usa la misma validación.
- El chatbot no limitaba el largo del mensaje. Ahora acepta hasta 500 caracteres y todos sus prompts incluyen una regla contra la revelación de instrucciones. El historial de conversación rechaza mensajes con rol `system`.

**Pendiente:** prueba manual de *prompt injection* contra el LLM real (SEC-24).

## A06 — Diseño inseguro

**Qué se probó:** manipulación de precios, sobreventa y límites de cantidad. **Resultado:** el total del checkout se recalcula con el precio de la base de datos y el stock se descuenta en una transacción con `UPDATE ... WHERE stock >= cantidad`. Se agregó un tope de 10 unidades por producto en el carrito, aplicado en frontend y backend (SEC-28).

**Pendiente:** controles del checkout de invitado, como rate limit y bloqueo tras pagos rechazados (SEC-29, SFTWRKEY-395).

## A07 — Fallas de autenticación

**Qué se probó:** fuerza bruta, enumeración de usuarios, contraseñas débiles y credenciales por defecto. **Resultado:** el login responde igual y en un tiempo similar ante un usuario inexistente o una contraseña incorrecta. Con `trust proxy`, el rate limit bloquea solo la IP atacante (SEC-31). **Abiertos (SFTWRKEY-381):**

- **Crítico:** `seed.js` crea `admin@luxor.com` con una contraseña publicada en el repositorio, y se ejecuta en cada despliegue (SEC-30).
- `/register` no tiene rate limit (SEC-32).
- La contraseña mínima es de 6 caracteres, sin más reglas (SEC-33).

**Aceptados:** ver la sección 7.

## A08 — Fallas de integridad de software y datos

**Resultado:** el CI instala con `npm ci` desde el lockfile y ejecuta los tres conjuntos de pruebas en cada push. Los datos externos (PerfumAPI y CSV) se validan antes de guardarse. Las dependencias del chatbot no tenían versión fija; se fijaron con `==` (SEC-37).

## A09 — Fallas de registro y alertas

**Resultado:** cada login fallido y cada bloqueo del rate limit se registra en `security_events`, y el administrador recibe una alerta cuando una IP supera 10 intentos fallidos en 15 minutos (SFTWRKEY-401). Ningún log imprime el cuerpo de las peticiones, que puede traer contraseñas o datos de tarjeta.

## A10 — Manejo inadecuado de condiciones excepcionales

**Resultado:** un manejador global devuelve errores genéricos en JSON: 400 para JSON malformado, 413 para cuerpos demasiado grandes y 404 para rutas inexistentes, siempre sin stack trace. El checkout, el carrito y la importación usan transacciones con `ROLLBACK`. Las caídas de la pasarela de pago y de PerfumAPI responden 502 controlado. **Pendiente:** probar la caída del proveedor del LLM (SEC-44).

## 5. Hallazgos y correcciones

| ID     | Hallazgo                                                                      | Severidad | Estado                                       | Ticket       |
|--------|-------------------------------------------------------------------------------|-----------|----------------------------------------------|--------------|
| SEC-30 | Administrador con contraseña pública creado en producción                     | Crítica   | <b>Abierto</b>                               | SFTWRKEY-381 |
| SEC-07 | Rate limit compartido por todos los usuarios (sin <code>trust proxy</code> )  | Alta      | Corregido y verificado                       | SFTWRKEY-380 |
| SEC-08 | <code>POST /chatbot/queries</code> público que escribe en la base             | Alta      | Corregido y verificado                       | SFTWRKEY-380 |
| SEC-31 | Fuerza bruta: límite no efectivo por IP en producción                         | Alta      | Corregido y verificado                       | SFTWRKEY-380 |
| SEC-15 | 8 vulnerabilidades altas en dependencias del frontend                         | Media     | Corregido y verificado                       | SFTWRKEY-382 |
| SEC-06 | API sin cabeceras de seguridad                                                | Media     | Corregido y verificado                       | SFTWRKEY-380 |
| SEC-09 | Endpoint de prueba <code>/chat/test-log</code> expuesto                       | Media     | Corregido y verificado                       | SFTWRKEY-380 |
| SEC-10 | Errores de base de datos devueltos al cliente                                 | Media     | Corregido y verificado                       | SFTWRKEY-380 |
| SEC-11 | Sitio sin CSP, <code>X-Frame-Options</code> ni HSTS                           | Media     | Corregido (se reverifica después del deploy) | SFTWRKEY-380 |
| SEC-42 | Stack traces en errores no controlados                                        | Media     | Corregido y verificado                       | SFTWRKEY-380 |
| SEC-23 | <code>PUT /products</code> sin validación                                     | Media     | Corregido y verificado                       | SFTWRKEY-379 |
| SEC-24 | Chatbot sin límite de mensaje ni defensa ante <i>prompt injection</i>         | Media     | Corregido (falta prueba con el LLM real)     | SFTWRKEY-379 |
| SEC-40 | Logins fallidos sin registro ni alerta                                        | Media     | Corregido y verificado                       | SFTWRKEY-401 |
| SEC-32 | <code>/register</code> sin rate limit                                         | Media     | <b>Abierto</b>                               | SFTWRKEY-381 |
| SEC-33 | Política de contraseñas débil                                                 | Media     | <b>Abierto</b>                               | SFTWRKEY-381 |
| ZAP    | CSP de la API con comodines y sin directivas de respaldo; 404 en HTML         | Media     | Corregido y verificado                       | SFTWRKEY-384 |
| SEC-12 | Contenedor como <code>root</code> con dependencias de desarrollo              | Baja      | Corregido y verificado                       | SFTWRKEY-380 |
| SEC-13 | CORS del chatbot demasiado permisivo                                          | Baja      | Corregido y verificado                       | SFTWRKEY-380 |
| SEC-22 | Campo <code>image</code> acepta <code>javascript:</code> y <code>http:</code> | Baja      | Corregido y verificado                       | SFTWRKEY-379 |
| SEC-28 | Carrito sin tope de cantidad                                                  | Baja      | Corregido y verificado                       | SFTWRKEY-391 |
| SEC-37 | Dependencias del chatbot sin versión fija                                     | Baja      | Corregido y verificado                       | SFTWRKEY-382 |
| SEC-45 | Token sin <code>id</code> autorizaba <code>/user/undefined</code>             | Baja      | Corregido y verificado                       | SFTWRKEY-378 |
| ZAP    | API sin <code>Permissions-Policy</code>                                       | Baja      | Corregido y verificado                       | SFTWRKEY-384 |

## 6. Escaneos OWASP ZAP

| Objetivo                       | FAIL | Altos | Medios | Bajos | Informativos |
|--------------------------------|------|-------|--------|-------|--------------|
| Frontend en producción         | 0    | 0     | 4      | 2     | 4            |
| API local, antes de corregir   | 0    | 0     | 3      | 2     | 1            |
| API local, después de corregir | 0    | 0     | 0      | 1     | 1            |

Clasificación de los avisos del frontend:

| Aviso                                                                                     | Riesgo      | Clasificación       | Justificación                                                                                                                                                                                                                                                                        |
|-------------------------------------------------------------------------------------------|-------------|---------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| CSP: directiva con comodín                                                                | Medio       | Mitigado y aceptado | <code>connect-src</code> se restringió a las URLs exactas de la API y del chatbot. <code>img-src https:</code> se mantiene porque las imágenes de productos pueden venir de cualquier proveedor <code>https</code> registrado por el administrador; las imágenes no ejecutan código. |
| CSP: <code>style-src 'unsafe-inline'</code>                                               | Medio       | Aceptado            | Lo requieren los estilos que inyecta el botón oficial de Google Sign-In. Los scripts inline siguen bloqueados.                                                                                                                                                                       |
| Cross-Domain Misconfiguration ( <code>Access-Control-Allow-Origin: *</code> )             | Medio       | Falso positivo      | Vercel lo aplica a archivos estáticos públicos (JS, CSS, imágenes), que no contienen datos privados ni usan credenciales.                                                                                                                                                            |
| Falta Subresource Integrity                                                               | Medio       | Aceptado            | Afecta la hoja de estilos de Google Fonts, que Google genera según el navegador y cambia de contenido, así que no admite un hash fijo.                                                                                                                                               |
| Falta <code>Cross-Origin-Embedder-Policy</code> / <code>Cross-Origin-Opener-Policy</code> | Bajo        | Aceptado            | COEP bloquearía las imágenes de otros dominios y COOP rompe la ventana emergente de Google Sign-In. El sitio no usa APIs que las requieran.                                                                                                                                          |
| Comentarios sospechosos, caché, aplicación moderna                                        | Informativo | Falso positivo      | Son textos de la interfaz dentro del JavaScript minificado y cabeceras de caché de Vercel.                                                                                                                                                                                           |

En la API se corrigieron todos los avisos medios. Quedan un bajo (COEP, que no aplica a una API JSON) y un informativo (respuestas cacheables del catálogo público).

## 7. Riesgos aceptados y recomendaciones

| Riesgo                                                        | Justificación                                                                                 | Recomendación futura                                                 |
|---------------------------------------------------------------|-----------------------------------------------------------------------------------------------|----------------------------------------------------------------------|
| El registro responde 409 si el correo ya existe (enumeración) | Necesario para la usabilidad del formulario                                                   | Mitigarlo con el rate limit de <code>/register</code> (SFTWRKEY-381) |
| JWT guardado en <code>localStorage</code>                     | Un XSS podría leerlo. Está mitigado por la CSP y por el escape de React (sin XSS encontrados) | Migrar a cookie <code>httpOnly</code> + <code>SameSite</code>        |
| Rate limit en memoria                                         | Válido con una sola instancia de la API, como ahora                                           | Usar Redis si se escala a varias instancias                          |

**Antes de entregar:** cerrar SFTWRKEY-381 (SEC-30, SEC-32 y SEC-33) y cambiar en producción la contraseña de la cuenta de administrador de demostración.

**Verificaciones pendientes:** SEC-05 (páginas de administración con una cuenta de cliente), SEC-24 y SEC-44 (chatbot con el LLM real), SEC-29 (checkout de invitado, SFTWRKEY-395) y SEC-36 (login con Google, SFTWRKEY-398).

## 8. Anexos

| Anexo                                   | Archivo                                    |
|-----------------------------------------|--------------------------------------------|
| A. Matriz de riesgos OWASP (45 riesgos) | <code>docs/security/MATRIZ_OWASP.md</code> |

| Anexo                                   | Archivo                                                                           |
|-----------------------------------------|-----------------------------------------------------------------------------------|
| B. ZAP — frontend en producción         | docs/security/anexos/zap-frontend-produccion.html                                 |
| C. ZAP — API antes y después            | docs/security/anexos/zap-api-local-antes.html, zap-api-local-despues.html         |
| D. npm audit — frontend antes y después | docs/security/anexos/npm-audit-frontend-antes.txt, npm-audit-frontend-despues.txt |
| E. npm audit — backend                  | docs/security/anexos/npm-audit-backend.txt                                        |
| F. pip-audit — chatbot                  | docs/security/anexos/pip-audit-chatbot.txt                                        |
| G. Pruebas automáticas                  | Archivos de la sección 3; se ejecutan en el CI (.github/workflows/tests.yml)      |

# Anexo A — Matriz de riesgos OWASP Top 10 — Perfumería Victoria

Marco: OWASP Top 10 (2025) · Última actualización: 29/09/2026

Documento vivo del Sprint 8. Se actualiza cada vez que se termina una tarea de seguridad y al cierre se exporta a PDF como anexo del informe.

## Cómo leer y actualizar la matriz

| Columna   | Valores                                                                                                                                                                                                                                                  |
|-----------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Resultado | Pasa = el control existe y funciona · Falla = hay un riesgo confirmado · Pendiente = todavía no se evalúa                                                                                                                                                |
| Método    | RC = revisión de código (27/09/2026, base del Sprint 8) · PA = prueba automática · PM = prueba manual · ZAP = escaneo OWASP ZAP · AUD = auditoría de dependencias                                                                                        |
| Severidad | Crítica = control de cuentas ADMIN o datos de cualquier usuario, sin autenticarse · Alta = expone datos personales, permite fraude o una denegación de servicio sencilla · Media = impacto limitado o requiere condiciones extra · Baja = buena práctica |
| Estado    | Abierto · Corregido · Verificado (corregido y con prueba que lo confirma) · Aceptado (riesgo asumido y justificado)                                                                                                                                      |

### Al terminar una tarea de seguridad:

1. Cambiar **Resultado**, **Método** y **Estado** de las filas de esa tarea.
2. Si la corrección tiene una prueba automática, anotar su nombre en **Prueba**.
3. Actualizar el resumen de abajo.

Los resultados marcados RC salen solo de la lectura del código. Cada uno se confirma con la prueba de su ticket antes de pasar a Verificado.

## Resumen por categoría

| Categoría                                 | Filas | Pasa | Falla | Pendiente |
|-------------------------------------------|-------|------|-------|-----------|
| A01 Pérdida de control de acceso          | 6     | 5    | 0     | 1         |
| A02 Configuración de seguridad incorrecta | 9     | 9    | 0     | 0         |
| A03 Cadena de suministro de software      | 2     | 2    | 0     | 0         |
| A04 Fallas criptográficas                 | 3     | 3    | 0     | 0         |
| A05 Inyección                             | 6     | 6    | 0     | 0         |
| A06 Diseño inseguro                       | 4     | 3    | 0     | 1         |
| A07 Fallas de autenticación               | 7     | 2    | 4     | 1         |
| A08 Integridad de software y datos        | 3     | 3    | 0     | 0         |
| A09 Registro y alertas                    | 2     | 2    | 0     | 0         |
| A10 Condiciones excepcionales             | 3     | 2    | 0     | 1         |
| Total                                     | 45    | 37   | 4     | 4         |

Riesgos abiertos (Falla + Abierto) por severidad: 1 Crítica · 0 Altas · 2 Medias · 0 Bajas. SEC-35 está en **Falla** pero como riesgo **Aceptado**.

Matriz

| ID     | Cat. | Componente | Endpoint / archivo                                                                                            | Riesgo                                                                                                                                        | Prueba                                                                                                                                                                                                                                                                                                | Resultado | Método | Severidad | Ticket       | Estado     |
|--------|------|------------|---------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|--------|-----------|--------------|------------|
| SEC-01 | A01  | Backend    | GET/PUT /user/:userId, GET /user/:userId/orders, PUT /user/:userId/password                                   | Un cliente lee o modifica el perfil, pedidos o contraseña de otro usuario (IDOR)                                                              | IDOR: cliente 7 contra /user/999, /user/999/orders y /user/999/password → 403; ids alterados (/user/07, /user/7abc, /user/%207) → 403; PUT /user/7 ignora role e id del body (security.accessControl.test.js, authorization.test.js)                                                                  | Pasa      | PA     | Alta      | SFTWRKEY-378 | Verificado |
| SEC-02 | A01  | Backend    | GET/POST /cart/:userId, POST /checkout/:userId                                                                | Un cliente ve o altera el carrito de otro, o compra a su nombre                                                                               | Cliente 7 contra /cart/999 (GET/POST) y /checkout/999 → 403; ids alterados (/cart/7.0, /cart/-7) → 403; un VENDEDOR tampoco accede → 403 (security.accessControl.test.js, authorization.test.js)                                                                                                      | Pasa      | PA     | Alta      | SFTWRKEY-378 | Verificado |
| SEC-03 | A01  | Backend    | POST/PUT/DELETE /products, /report*, /users/search, /imports/*, /external-perfumes/*, /admin/perfum-sync-logs | Un CLIENTE usa funciones de administrador                                                                                                     | CLIENTE y VENDEDOR contra productos, /report/* (las 6 rutas), /users/search, /imports/* (incluida la plantilla) y /external-perfumes/* → 403 sin consultar la BD; /register siempre crea CLIENTE (security.accessControl.test.js, authorization.test.js)                                              | Pasa      | PA     | Crítica   | SFTWRKEY-378 | Verificado |
| SEC-04 | A01  | Backend    | services/auth.js (authenticate)                                                                               | Acceso con un token ausente, vencido, firmado con otro secreto o con un esquema distinto de Bearer                                            | Sin token, token alterado, firmado con otra clave, vencido, alg: none, rol cambiado en el payload, esquemas Basic / Token / Bearer vacío → 401 (security.accessControl.test.js, authorization.test.js)                                                                                                | Pasa      | PA     | Crítica   | SFTWRKEY-378 | Verificado |
| SEC-05 | A01  | Frontend   | Páginas /admin*, /reporte                                                                                     | La interfaz de admin se muestra a un cliente (el control real está en el backend)                                                             | Entrar como CLIENTE y abrir cada ruta; ninguna llamada de admin responde 200                                                                                                                                                                                                                          | Pendiente | —      | Baja      | SFTWRKEY-378 | Abierto    |
| SEC-06 | A02  | Backend    | server.js                                                                                                     | Faltan cabeceras de seguridad (HSTS, nosniff, frameguard) y se expone X-Powered-By                                                            | Se agregó helmet: /products responde con HSTS, nosniff, X-Frame-Options y CSP, sin X-Powered-By (security.config.test.js; verificado también en Docker)                                                                                                                                               | Pasa      | PA     | Media     | SFTWRKEY-380 | Verificado |
| SEC-07 | A02  | Backend    | server.js, services/rateLimit.js                                                                              | Sin trust proxy, en Render todas las peticiones comparten la IP del proxy: el rate limit bloquea a todos a la vez y no identifica al atacante | Se agregó trust proxy: 11 logins fallidos desde 203.0.113.10 → 429 solo para esa IP; otra IP sigue recibiendo 401 (security.config.test.js)                                                                                                                                                           | Pasa      | PA     | Alta      | SFTWRKEY-380 | Verificado |
| SEC-08 | A02  | Backend    | POST /chatbot/queries                                                                                         | Endpoint público que escribe en la BD: cualquiera puede llenar la tabla chatbot_queries                                                       | Ahora exige X-Internal-Key (services/internalKey.js, comparación en tiempo constante, rechaza todo si falta la variable): sin clave, con una incorrecta o con un token de ADMIN → 401; con la correcta → 201 (security.config.test.js). En Docker el chatbot sigue registrando consultas con la clave | Pasa      | PA     | Alta      | SFTWRKEY-380 | Verificado |
| SEC-09 | A02  | Chatbot    | POST /chat/test-log (app/bot/router.py)                                                                       | Endpoint de prueba expuesto en producción que genera registros falsos                                                                         | Se eliminó la ruta: POST /chat/test-log → 404 (verificado en Docker)                                                                                                                                                                                                                                  | Pasa      | PM     | Media     | SFTWRKEY-380 | Verificado |

| ID     | Cat. | Componente         | Endpoint / archivo                         | Riesgo                                                                                                | Prueba                                                                                                                                                                                                                                                                                                 | Resultado | Método | Severidad | Ticket       | Estado     |
|--------|------|--------------------|--------------------------------------------|-------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|--------|-----------|--------------|------------|
| SEC-10 | A02  | Backend            | POST /imports/products (catch)             | Se devuelve err.message de cualquier error, incluidos los internos de la BD                           | CsvValidationError: separa los errores de validación (400 con su mensaje) de los internos (500 genérico). Un error simulado de BD no filtra su mensaje ( security.config.test.js )                                                                                                                     | Pasa      | PA     | Media     | SFTWRKEY-380 | Verificado |
| SEC-11 | A02  | Frontend           | vercel.json                                | Sin CSP, X-Frame-Options ni HSTS en el sitio (clickjacking, impacto mayor de un XSS)                  | Se agregaron a vercel.json CSP, X-Frame-Options: DENY, HSTS, nosniff, Referrer-Policy y Permissions-Policy. Se sirvió el build de producción con esas cabeceras: home, catálogo, detalle, login con la API y chatbot sin violaciones de CSP. Falta securityheaders.com sobre Vercel después del deploy | Pasa      | PM     | Media     | SFTWRKEY-380 | Corregido  |
| SEC-12 | A02  | Infraestructura    | backend/Dockerfile                         | El contenedor corre como root y usa npm install, que instala dependencias de desarrollo en producción | El Dockerfile usa NODE_ENV=production, npm ci --omit=dev y USER node, y se agregó backend/.dockerignore. En Docker, whoami → node                                                                                                                                                                      | Pasa      | PM     | Baja      | SFTWRKEY-380 | Verificado |
| SEC-13 | A02  | Chatbot            | app/main.py (CORS)                         | CORS con allow_credentials=True y métodos y cabeceras *, más permisivo de lo necesario                | Ahora allow_credentials=False, métodos GET, POST y cabecera Content-Type. Preflight desde localhost:5173 → 200 con esos valores (verificado en Docker)                                                                                                                                                 | Pasa      | PM     | Baja      | SFTWRKEY-380 | Verificado |
| SEC-14 | A02  | Backend            | server.js (CORS)                           | Otros orígenes llaman a la API desde el navegador                                                     | Origin distinto de FRONTEND_URL → sin cabecera CORS                                                                                                                                                                                                                                                    | Pasa      | RC     | Media     | SFTWRKEY-380 | Abierto    |
| SEC-15 | A03  | Frontend / Backend | package.json, backend/package.json         | Dependencias npm con vulnerabilidades conocidas                                                       | Frontend: 12 vulnerabilidades (8 altas; en producción, react-router y react-router-dom) → 0 con npm audit fix sin --force (react-router 7.18.4, vite 8.3.1). Backend: 0. Pruebas y build siguen pasando (anexos/npm-audit-*.txt)                                                                       | Pasa      | AUD    | Media     | SFTWRKEY-382 | Verificado |
| SEC-16 | A03  | Chatbot            | backend/chatbot/requirements.txt           | Dependencias pip con vulnerabilidades conocidas                                                       | pip-audit -r requirements.txt → "No known vulnerabilities found" (anexos/pip-audit-chatbot.txt)                                                                                                                                                                                                        | Pasa      | AUD    | Media     | SFTWRKEY-382 | Verificado |
| SEC-17 | A04  | Backend            | services/authHandlers.js                   | Contraseñas guardadas en claro o con un hash débil                                                    | bcrypt con 12 rondas en registro y cambio de contraseña                                                                                                                                                                                                                                                | Pasa      | RC     | Crítica   | SFTWRKEY-381 | Abierto    |
| SEC-18 | A04  | Backend            | services/auth.js                           | Tokens JWT falsificables (secreto débil o alg: none)                                                  | HS256 con JWT_SECRET generado por Render, 8 h de validez; un token alg: none → 401                                                                                                                                                                                                                     | Pasa      | RC     | Crítica   | SFTWRKEY-381 | Abierto    |
| SEC-19 | A04  | Infraestructura    | Vercel, Render                             | Tráfico sin cifrar                                                                                    | Todo el tráfico es HTTPS (lo gestiona cada proveedor)                                                                                                                                                                                                                                                  | Pasa      | RC     | Alta      | SFTWRKEY-380 | Abierto    |
| SEC-20 | A05  | Backend            | Todo el SQL de server.js y services/       | Inyección SQL                                                                                         | 6 payloads ( ' OR '1'='1, DROP TABLE, UNION SELECT, pg_sleep...) contra /products/search, /login, /users/search y /products/:id: viajan como parámetro y nunca en el texto SQL ( security.injection.test.js ). Búsqueda de SQL con \${} interpolado: 0 coincidencias                                   | Pasa      | PA     | Crítica   | SFTWRKEY-379 | Verificado |
| SEC-21 | A05  | Frontend           | Catálogo, detalle, carrito, admin, chatbot | XSS almacenado desde nombre o descripción del producto, CSV o respuestas del bot                      | <script> e <img onerror> en nombre, descripción y notas de ProductCard y ProductDetail, y en una respuesta del chatbot: se muestran como texto, sin crear elementos ni ejecutar código ( src/test/xss.test.tsx ). No hay dangerouslySetInnerHTML                                                       | Pasa      | PA     | Alta      | SFTWRKEY-379 | Verificado |

| ID     | Cat. | Componente         | Endpoint / archivo                                   | Riesgo                                                                                            | Prueba                                                                                                                                                                                                                               | Resultado | Método | Severidad | Ticket       | Estado     |
|--------|------|--------------------|------------------------------------------------------|---------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|--------|-----------|--------------|------------|
| SEC-22 | A05  | Backend            | POST/PUT /products, csvImport.js (campo image)       | image acepta cualquier cadena (javascript:, data:, http:)                                         | javascript:, data:, http:, //host, rutas sin / y más de 500 caracteres → 400 en POST y PUT, y error de fila en el CSV. Vacío, /ruta y https:// → aceptados. Se corrigió con services/imageValidation.js (security.injection.test.js) | Pasa      | PA     | Baja      | SFTWRKEY-379 | Verificado |
| SEC-23 | A05  | Backend            | PUT /products/:id                                    | No usa validateProductPayload (el POST sí): acepta tipos y longitudes inválidos                   | Ahora usa validateProductPayload: stock: "abc" y un nombre de 201 caracteres → 400 (security.injection.test.js); las pruebas anteriores del PUT siguen pasando                                                                       | Pasa      | PA     | Media     | SFTWRKEY-379 | Verificado |
| SEC-24 | A05  | Chatbot            | POST /chat (app/bot/models.py, service.py)           | Prompt injection y mensajes sin límite de tamaño (costo y abuso del LLM)                          | max_length=500 y la regla contra prompt injection. tests/test_security.py pasa (26/26 en pytest, ejecutado en un contenedor Python 3.12). Falta la prueba manual con el LLM real                                                     | Pasa      | PA     | Media     | SFTWRKEY-379 | Corregido  |
| SEC-25 | A05  | Backend            | POST /imports/products                               | Inyección a través de los campos del CSV                                                          | Los valores del CSV se insertan como parámetros, y una fila con imagen javascript: queda marcada con error (security.injection.test.js)                                                                                              | Pasa      | PA     | Media     | SFTWRKEY-379 | Verificado |
| SEC-26 | A06  | Backend            | POST /checkout/:userId                               | El cliente manipula el precio o el total                                                          | El total se recalcula con products.price de la BD                                                                                                                                                                                    | Pasa      | RC     | Alta      | SFTWRKEY-378 | Abierto    |
| SEC-27 | A06  | Backend            | POST /checkout/:userId                               | Sobreventa por compras simultáneas                                                                | UPDATE ... WHERE stock >= \$1 dentro de una transacción                                                                                                                                                                              | Pasa      | RC     | Media     | SFTWRKEY-387 | Abierto    |
| SEC-28 | A06  | Backend            | POST /cart/:userId (validateCartItems)               | Sin tope de cantidad por producto                                                                 | quantity: 11 → 400 y quantity: 10 → 200 (cartLimits.test.js). El frontend aplica el mismo tope y el stock real (cartLimits.ts, CartContext.test.tsx)                                                                                 | Pasa      | PA     | Baja      | SFTWRKEY-391 | Verificado |
| SEC-29 | A06  | Backend            | POST /checkout/guest (nuevo)                         | Abuso del checkout público: prueba de tarjetas robadas, precio manipulado, pedidos masivos        | Rate limit, bloqueo tras 3 rechazos, precio de la BD                                                                                                                                                                                 | Pendiente | —      | Alta      | SFTWRKEY-395 | Abierto    |
| SEC-30 | A07  | BD / Seed          | backend/seed.js                                      | admin@luxor.com con contraseña 123456 (publicada en el repo) se crea en cada deploy de producción | Intentar entrar en producción con esas credenciales → 401                                                                                                                                                                            | Falla     | RC     | Crítica   | SFTWRKEY-381 | Abierto    |
| SEC-31 | A07  | Backend            | POST /login                                          | Fuerza bruta: el límite de 10/min existe pero no funciona por IP en Render (ver SEC-07)           | Con trust proxy (SEC-07), 11 intentos desde la misma IP → 429 solo para esa IP (security.config.test.js, authorization.test.js)                                                                                                      | Pasa      | PA     | Alta      | SFTWRKEY-381 | Verificado |
| SEC-32 | A07  | Backend            | POST /register                                       | Sin rate limit: creación masiva de cuentas                                                        | 6 registros por hora desde la misma IP → 429                                                                                                                                                                                         | Falla     | RC     | Media     | SFTWRKEY-381 | Abierto    |
| SEC-33 | A07  | Backend / Frontend | authHandlers.js, PUT /user/:id/password, formularios | Contraseñas débiles (mínimo 6 caracteres, sin más reglas)                                         | "abcdefgh" y "12345678" → 400                                                                                                                                                                                                        | Falla     | RC     | Media     | SFTWRKEY-381 | Abierto    |
| SEC-34 | A07  | Backend            | POST /login, POST /register                          | Enumeración de usuarios                                                                           | Login: mismo 401 y tiempo similar (DUMMY_HASH) con usuario inexistente o clave incorrecta. Registro: responde 409 si el correo existe                                                                                                | Pasa      | RC     | Baja      | SFTWRKEY-381 | Aceptado   |

| ID     | Cat. | Componente        | Endpoint / archivo                                          | Riesgo                                                                                                                                  | Prueba                                                                                                                                                                                                                                                                                                                                                                                                                                                                              | Resultado | Método | Severidad | Ticket       | Estado     |
|--------|------|-------------------|-------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|--------|-----------|--------------|------------|
| SEC-35 | A07  | Frontend          | AuthContext.tsx, apiClient.ts                               | JWT en localStorage: un XSS podría robarlo                                                                                              | Mitigado con la CSP (SEC-11) y el escape de React (SEC-21). La migración a cookie httpOnly queda para un sprint futuro                                                                                                                                                                                                                                                                                                                                                              | Falla     | RC     | Media     | SFTWRKEY-380 | Aceptado   |
| SEC-36 | A07  | Backend           | POST /auth/google (nuevo), users.password NULL              | Login con Google: token no verificado, correo no verificado, o login con contraseña vacía en cuentas de Google                          | Token inválido → 401; email_verified: false → 401; cuenta de Google con clave vacía → 401                                                                                                                                                                                                                                                                                                                                                                                           | Pendiente | —      | Alta      | SFTWRKEY-398 | Abierto    |
| SEC-37 | A08  | Chatbot           | backend/chatbot/requirements.txt                            | Dependencias sin versión fija: builds no reproducibles                                                                                  | Versiones fijadas con == en requirements.txt (las que resolvía pip el 29/09/2026); las 74 pruebas del chatbot pasan con esas versiones                                                                                                                                                                                                                                                                                                                                              | Pasa      | PA     | Baja      | SFTWRKEY-382 | Verificado |
| SEC-38 | A08  | CI                | .github/workflows/tests.yml, package-lock.json              | Instalaciones no reproducibles o sin pruebas                                                                                            | npm ci con lockfile y 3 jobs de pruebas en cada push                                                                                                                                                                                                                                                                                                                                                                                                                                | Pasa      | RC     | Baja      | SFTWRKEY-382 | Abierto    |
| SEC-39 | A08  | Backend           | services/perfumValidation.js, parfumMapper.js, csvImport.js | Datos externos (PerfumAPI, CSV) guardados sin validar                                                                                   | Se validan URL, tipos y campos antes de guardar                                                                                                                                                                                                                                                                                                                                                                                                                                     | Pasa      | RC     | Media     | SFTWRKEY-379 | Abierto    |
| SEC-40 | A09  | Backend           | authHandlers.js, rateLimit.js                               | Los logins fallidos y los bloqueos no se registran ni generan alertas: un ataque pasa desapercibido                                     | Cada login fallido y cada bloqueo del rate limit se guardan en security_events (IP, correo y ruta; nunca la contraseña), en services/securityEvents.js. 10 logins fallidos desde una IP, o contra una misma cuenta, en 15 minutos → alerta en GET /admin/security-alerts y en el panel (SecurityAlerts.tsx). Solo ADMIN (CLIENTE/VENDEDOR → 403). Si falla el registro, el login responde igual (security.alerts.test.js, SecurityAlerts.test.tsx; SQL verificado en PostgreSQL 16) | Pasa      | PA     | Media     | SFTWRKEY-401 | Verificado |
| SEC-41 | A09  | Backend           | console.error en rutas                                      | Datos sensibles (tarjeta, contraseñas) en los logs                                                                                      | Ningún log imprime req.body (búsqueda: 0 coincidencias)                                                                                                                                                                                                                                                                                                                                                                                                                             | Pasa      | RC     | Alta      | SFTWRKEY-380 | Abierto    |
| SEC-42 | A10  | Backend           | server.js (sin manejador global de errores)                 | Sin NODE_ENV=production, el manejador por defecto de Express devuelve el stack trace ante un JSON malformado u otro error no controlado | Manejador global de errores y NODE_ENV=production en el Dockerfile: un JSON malformado → 400 genérico y un body de 3 MB → 413 genérico, sin stack trace (security.config.test.js)                                                                                                                                                                                                                                                                                                   | Pasa      | PA     | Media     | SFTWRKEY-380 | Verificado |
| SEC-43 | A10  | Backend           | Checkout, carrito, importación CSV                          | Datos inconsistentes si falla una operación a la mitad                                                                                  | BEGIN / COMMIT / ROLLBACK en las tres operaciones                                                                                                                                                                                                                                                                                                                                                                                                                                   | Pasa      | RC     | Alta      | SFTWRKEY-378 | Abierto    |
| SEC-44 | A10  | Chatbot / Backend | Pasarela de pago, PerfumAPI, proveedor del LLM              | Una caída de un servicio externo produce errores 500 o respuestas colgadas                                                              | Pasarela y PerfumAPI → 502 controlado (RC). Falta probar la caída del LLM (Groq u Ollama)                                                                                                                                                                                                                                                                                                                                                                                           | Pendiente | —      | Media     | SFTWRKEY-379 | Abierto    |
| SEC-45 | A01  | Backend           | services/auth.js (authorizeSelfOrRoles)                     | Un token válido sin id autorizaba /user/undefined, porque String(undefined) === "undefined". Se corrigió exigiendo id                   | Token sin id contra /user/7 y /user/undefined → 403 (security.accessControl.test.js)                                                                                                                                                                                                                                                                                                                                                                                                | Pasa      | PA     | Baja      | SFTWRKEY-378 | Verificado |

Escaneo dinámico

| ID     | Alcance                                                   | Prueba                          | Resultado                                                            | Ticket       |
|--------|-----------------------------------------------------------|---------------------------------|----------------------------------------------------------------------|--------------|
| ZAP-01 | Frontend en producción ( luxor-project-green.vercel.app ) | zap-baseline.py                 | Pasa: 0 FAIL, 0 altos; 4 medios aceptados o mitigados (ver informe)  | SFTWRKEY-383 |
| ZAP-02 | API local ( localhost:3000 , mismo código que producción) | zap-baseline.py antes y después | Pasa: de 3 medios + 2 bajos a 0 medios; queda 1 bajo aceptado (COEP) | SFTWRKEY-383 |

Las alertas de ZAP que no estén ya cubiertas por la matriz se agregan como filas nuevas ( SEC-45 en adelante).